

Módulo 5: Superficie del Servidor

T15: SSRF y APIs Expuestas

Carlos Rodríguez Contreras · GitHub: karrocon

 *Hacer que el servidor llame a URLs que tú controlas*

Objetivos

- Entender cómo funciona Server-Side Request Forgery (SSRF)
- Explotar un endpoint de VulnApp que hace fetch a URLs arbitrarias
- Acceder a metadatos del servidor de nube (AWS/GCP IMDS) mediante SSRF
- Implementar una allowlist de dominios/IPs como defensa

En construcción

Este topic todavía no tiene slides completas.

Usa las diapositivas maestras (`slides-curso.html`) como referencia del contenido previsto.



Lab T15: SSRF en el endpoint de preview

Objetivo: hacer que VulnApp llame a una URL interna mediante SSRF

Setup: `cd VulnApp && npm start`

1. Llama a `POST /preview` con `{"url": "http://localhost:3000/debug"}`
2. Observa que el servidor hace fetch a su propia URL interna
3. Prueba con `{"url": "http://169.254.169.254/latest/meta-data/"}` (simulado)
4. Implementa una allowlist de dominios en `src/routes/` para mitigar SSRF